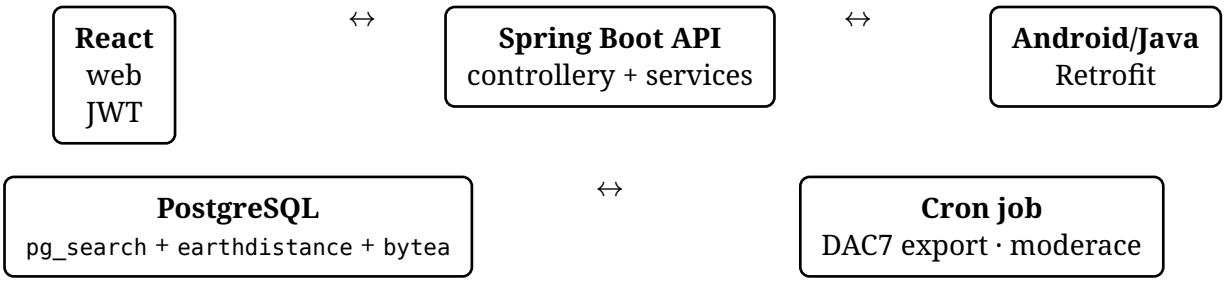
1 Cíl

- C2C bazar použitého zboží pro legální provoz v ČR.
- Jednotné REST API (Spring Boot) pro web (React) i mobil (Java / Android Studio).
- Chat: TLS + uložení na serveru kvůli moderaci.

2 Legální minimum

- **DAC7 (2021/514)** — sběr, ověření a roční report prodejních dat (Specializovaný finanční úřad).
  - Pole: jméno, datum narození, adresa, DIČ/IČO, částky, IBAN, poplatky.
  - Vyjmutí pro zboží: méně než 30 prodejů **a** max. 2 000 EUR ročně.
- **DSA čl. 30 (2022/2065)** — Know Your Business Customer jen pro obchodníky.
  - `sellerType: private | trader` určuje sběr dat i spotřebitelská práva.
  - Trader: IČO + kopie dokladu + čestné prohlášení.
- **DSA čl. 16/22 + 480/2004 Coll.** — notice-and-action, trusted flaggers, bezodkladný takedown.
  - Server hlášený obsah přímo čte a rozhodne.
- **GDPR + 110/2019 Coll.** — titul 6(1)(b) vs. 6(1)(c), oddělená úložiště, soft-delete s retencí DAC7, export, souhlasy.
- **Spotřebitel (89/2012, §1829/§1837 + Omnibus)** — 14denní odstoupení jen trader→spotřebitel, badge obchodník/soukromník, podmínky česky.

3 Architektura



- Backend: Spring Boot 3, Java 17, vrstvy controller → service → repository (Spring Data JPA), validace Bean Validation, Liquibase `V1__init.sql` → `V2__dac7.sql`.
- Auth: Spring Security, JWT access 15 min + refresh 30 dní, `password_hash` Argon2/bcrypt, rate-limit na `/auth/login`, `users.email citext unique`.
- Uživatelé a prodejce: entity `User(seller_type)`, `SellerTaxProfile(AES-GCM bytea, role app_reporting)`, endpointy `PATCH /users/me/seller-info`, `POST /users/me/id-document`, `GET /seller/me/dac7-status`.
- Inzeráty a obrázky: entity `Listing(status, seller_type_snapshot)`, `ListingImage(data bytea, mime, sort_order)`, multipart max 5 MB, EXIF strip, kontrola MIME `image/jpeg|png|webp`.
- Vyhledávání: extenze `pg_search` (BM25 index na `title, description, category, condition, city`) + `earthdistance` (`ll_to_earth`, radius v metrech), `GET /listings/search`, `GET /listings/feed`.
- Transakce a recenze: `Transaction(reserved→completed|cancelled, price_czk snapshot, completed_at)`, `Review(rating 1–5, verified_purchase, moderation_status)`, 1 recenze + 1 odpověď na transakci. `completed` = znalost provedení pro DAC7 (počítá se do `salesCount/totalAmount`), částka = snapshot ceny, ne dobrovolné přiznání prodejce.
- Chat: `Conversation(buyer, seller, listing unique)`, `Message(body_text)`, REST `POST /chat/messages`, `GET /chat/conversations/:id/messages`, TLS, kontrola účasti.
- Moderace: `Report(target_type, target_id, trusted_flagger, status)`, `POST /moderation/reports`, `GET /admin/moderation/queue`, takedown `approve|remove` s auditem.
- GDPR: `Consent(purpose, granted)`, `AuditLog`, `GET /users/me/export`, `DELETE /users/me` soft-delete (`deleted_at`), daňový profil retence.
- Admin/DAC7: `GET /admin/dac7/export?year` CSV/XML, cron 1× ročně, počítání `salesCount/totalAmount/isReportable`, blokace `422 DAC7_PROFILE_REQUIRED`.

4 Datový model

- `seller_tax_profile` oddělena od `users` (AES-GCM, role `app_reporting`).
- Veřejné endpointy daňový profil nečtou.
- Snapshot typu prodejce na inzerátu a transakci.
- Smazání účtu je soft-delete, daňový profil se uchovává (DAC7 retence).

- `messages.body_text` v plaintextu.
- Poloha inzerátu (`city` + volitelné `lat/lon` se souhlasem) se neodvozuje z DAC7 adresy.

users
`seller_type`
1:1 → tax_profile
1:N → listings

listings
snapshot typu
1:N → images
1:N → transactions

transactions
`reserved→completed`
1:1 → reviews

conversations
triple (buyer, seller, listing)
1:N → messages

reports
listing / review / chat
trusted priorita

consents + **audit_log**
souhlasy · audit akcí

```
create extension if not exists pg_search;
create extension if not exists earthdistance;
create table users (id bigserial primary key, email citext unique not null,
  password_hash text not null, display_name text not null,
  seller_type text not null check (seller_type in ('private','trader')),
  created_at timestamptz default now(), deleted_at timestamptz);
create table seller_tax_profile (user_id bigint primary key references users(id),
  full_name bytea not null, date_of_birth bytea not null, street bytea not null,
  city bytea not null, postal_code bytea not null, country bytea not null,
  tax_id bytea, ico bytea, iban bytea not null,
  self_cert boolean not null default false, id_doc_bytea bytea,
  verified boolean not null default false, updated_at timestamptz default now());
create table listings (id bigserial primary key,
  seller_id bigint not null references users(id), title text not null,
  description text not null, price_czk int not null check (price_czk > 0),
  category text not null, condition text not null, city text not null,
  lat double precision, lon double precision, seller_type_snapshot text not null,
  status text not null default 'active', created_at timestamptz default now());
create index listings_bm25_idx on listings
  using bm25 (id, title, description, category, condition, city)
  with (key_field = 'id');
create table listing_images (id bigserial primary key,
  listing_id bigint not null references listings(id) on delete cascade,
  data bytea not null, mime text not null, sort_order int not null default 0);
create table transactions (id bigserial primary key,
  listing_id bigint not null references listings(id),
  buyer_id bigint not null references users(id),
  seller_id bigint not null references users(id), price_czk int not null,
  status text not null default 'reserved'
    check (status in ('reserved','completed','cancelled')),
  seller_type_snapshot text not null, completed_at timestamptz);
create table reviews (id bigserial primary key,
  transaction_id bigint unique not null references transactions(id),
  reviewer_id bigint not null references users(id),
  reviewee_id bigint not null references users(id),
  listing_id bigint not null references listings(id),
  rating smallint not null check (rating between 1 and 5), text text not null,
  is_verified_purchase boolean not null default true,
  moderation_status text not null default 'visible', created_at timestamptz default now());
create table conversations (id bigserial primary key,
  listing_id bigint not null references listings(id),
  buyer_id bigint not null references users(id),
  seller_id bigint not null references users(id),
  created_at timestamptz default now(),
  unique (buyer_id, seller_id, listing_id));
create table messages (id bigserial primary key,
  conversation_id bigint not null references conversations(id) on delete cascade,
  sender_id bigint not null references users(id),
  body_text text not null, sent_at timestamptz default now());
create table reports (id bigserial primary key,
  target_type text not null check (target_type in ('listing','review','chat')),
  target_id bigint not null, reporter_id bigint not null references users(id),
  reason text not null,
```

```
  trusted_flagger boolean not null default false,
  status text not null default 'open', created_at timestamptz default now());
```

Společná pravidla:

- JSON, `Authorization: Bearer <JWT>`.
- Stránkování `{data, nextCursor}` (limit max 50).
- Chyby `400 / 401 / 403 / 404 / 409 / 422` s českým `{code, messageCs}`.

5 API — uživatelé a prodejce

Endpoint	Vstup	Výstup / pravidlo
`POST /auth/register`	`email, password(8+), displayName, sellerType`	`201 {id}` · hash Argon2/bcrypt · `409` duplicita
`POST /auth/login`	`email, password`	`{token, refreshToken}` · rate-limit
`GET /users/:id`	—	Veřejný profil · bez daňových sloupců
`GET /users/:id/badges`	—	`email/phone/trader/dac7` odznaky
`GET /users/:id/reviews`	`cursor`	Stránkované viditelné recenze + odpovědi
`PATCH /users/me/seller-info`	`sellerType, fullName, dateOfBirth, address, taxId, ico, iban, selfCertification`	Zápis do `seller_tax_profile` · trader: `ico` + doklad + `selfCert=true` · jinak `422`
`POST /users/me/id-document`	multipart `image/*,pdf`, 5 MB	`id_doc_bytea` · `verified=false`
`GET /seller/me/dac7-status`	—	`{salesCount, totalAmount, isReportable}` · blokace publikování

6 API — inzeráty, vyhledávání, transakce

Endpoint	Vstup	Výstup / pravidlo
`POST /listings`	`title, description, priceCzk, category, condition, city, lat?, lon?`	Snapshot typu · `422 DAC7_PROFILE_REQUIRED`
`PUT /listings/:id`	vlastník	editace aktivního inzerátu
`DELETE /listings/:id`	vlastník	soft-delete · transakce zůstávají
`POST /listings/:id/images`	multipart ⟶ `bytea`	EXIF strip · kontrola MIME
`DELETE /listings/:id/images/:img`	vlastník	smazání jednoho obrázku
`GET /listings/:id/rights-info`	—	`{withdrawalApplies, sellerType, explanationCs}`
`GET /listings/search`	`q, lat, lon, radiusKm, filtry, sort, cursor`	BM25 (`pdb.*`) + radius · kurzor `(key,id)`
`GET /listings/feed`	`cursor`	stejný tvar stránky · scroll
`POST /transactions`	`listingId`	rezervace kupujícím
`POST /transactions/:id/complete`	kupující/prodejce	`reserved→completed`
`POST /transactions/:id/cancel`	kupující/prodejce	`reserved→cancelled`
`POST /transactions/:id/review`	`rating 1–5, text`	1× · jen kupující · „Ověřený nákup„ · `409/403`
`POST /reviews/:id/response`	`text`	1 odpověď hodnoceného

7 API — chat, moderace, GDPR, admin

Endpoint	Vstup	Výstup / pravidlo
`POST /chat/conversations`	`listingId`	dedup (buyer, seller, listing) · „Napsat prodejci„
`POST /chat/messages`	`{conversationId, bodyText}`	plaintext · TLS · max 8 KB
`GET /chat/conversations/:id/messages`	`cursor`	stránkovaný plaintext · kontrola účasti
`POST /moderation/reports`	`targetType, targetId, reason`	fronta · trusted priorita · server obsah čte
`GET /admin/moderation/queue`	`ADMIN`	auditováno
`POST /admin/moderation/:id/...`	`approve | remove` · `ADMIN`	bezodkladný takedown
`GET /users/me/export`	—	přenositelnost dat
`DELETE /users/me`	—	soft-delete · daňový profil trvá

Endpoint	Vstup	Výstup / pravidlo
`POST /consents`	`{purpose, granted}`	evidence souhlasu
`POST /admin/dac7/export`	`?year` · `ADMIN`	CSV/XML · reprodukovatelný

Pole	Právní základ	Kdy vyžadovat
Jméno, adresa, datum narození	DAC7	při registraci · povinně po prahu
DIČ / IČO	DAC7 + daňové předpisy	při reportovatelnosti · vždy u obchodníka
Kopie dokladu	DSA čl. 30	pouze obchodník
Čestné prohlášení	DSA čl. 30(e)	pouze obchodník
IBAN	DAC7	při registraci · povinně po prahu

8 Vyhledávání (`pg_search` p_queries)

```
-- p_queries se vážou jako parametr, nikdy konkatenací
select l.*, paradedb.score(l.id) as score
from listings l
where l.status = 'active'
  and (:q is null or :q = '' or l.id @@@ pdb.parse(:q, lenient => true))
  and (:cat is null or l.category = :cat)
  and l.price_czk between :min and :max
  and (:lat is null or earth_distance(
        ll_to_earth(l.lat, l.lon), ll_to_earth(:lat, :lon)) <= :radiusM)
order by
  case when :sort = 'relevance' then paradedb.score(l.id) end desc,
  l.id desc
limit :limit+1;
```

Pravidla vyhledávání:

- `q` max 200 znaků.
- `lenient => true`.
- `sort` pouze z allowlistu.
- Kontrola rozsahů souřadnic a `radiusKm`.
- `limit` max 50.

9 Chat

- Doprava přes TLS.
- Server ukládá `messages.body_text`.
- Přístup: jen účastníci konverzace + `ADMIN` při hlášení.
- Hlášení: `POST /moderation/reports {targetType: chat, targetId}`

10 Klienti a zabezpečení

10.1 Web (React)

- Stránky: `/`, `/search`, `/listing/:id`, `/chat/:id`, `/profile/:id`, `/seller-info`, `/admin/*`.
- Komponenty: `SellerBadge`, `WithdrawalBanner`, `VerifiedReview`, `RadiusFilter`, `ConsentBanner`.

10.2 Mobil (Android / Java)

- Zrcadlové obrazovky k webu.
- Retrofit 1:1 k API.

10.3 Zabezpečení

- Vázané parametry ve všech dotazech (včetně `pdb.*`).
- Test payloady (`' OR '1'='1`, `; DROP TABLE`, Tantivy syntaxe).
- Escapování + CSP proti XSS.
- Kontrola vlastnictví.
- Rate-limit.
- CORS pro webový původ.